ChatGPT

# eMudhra weak CA keys

## 1. Quick facts

- **Short title:** eMudhra CA weak keys
- **Start date (UTC):** 2026-10-17
- **Category:** Cryptographic weakness
- **Severity:** Critical (CVE-2026-108015, CVSS 4.0 9.1【14†L216-L223】; CVE-2026-22063, CVSS 4.0 6.0【6†L406-L414】)
- **Who/what was affected:** Eight intermediate certificate authorities (CAs) of India's eMudhra had weak private keys【34†L128-L131】【38†L147-L155】. These CAs (six for TLS, two for code signing) were trusted by major browsers and OSs worldwide. No domestic Indian DSC/eSign services were affected【37†L139-L147】【38†L167-L170】. One U.S. customer ecosystem had ~30,800 certificates under the impacted hierarchy【26†L263-L268】.
- **Attacker:** No malicious attacker identified (keys were weak by mistake) – attribution: *unattributed* 【38†L147-L155】【41†L508-L516】.
- **CVE IDs:** CVE-2026-108015 (HCL Notes, CVSS 9.1)【14†L216-L223】; CVE-2026-22063 (NetApp products, CVSS 6.0)【6†L406-L414】; plus related CVEs assigned to track Go, Java, Python trust-store fixes【45†L147-L155】.
- **Current status:** All eight intermediates were revoked and major browsers blocked them【41†L500-L508】【20†L53-L61】. eMudhra has since exited the SSL/TLS certificate business【22†L102-L105】【46†L289-L298】. Trust store updates (CRLSet, OneCRL, Microsoft CTL, etc.) have been applied; only outdated clients might still trust the old keys.

## 2. One-paragraph summary

In mid-October 2026, eight intermediate CA keys of India's eMudhra were discovered to be extremely weak (tiny values)【38†L147-L155】【43†L28-L37】. Browsers (Chrome, Firefox, etc.) blocked them that day, and eMudhra revoked the certificates on Oct 18【20†L53-L61】【41†L500-L508】. No exploit has been seen (CERT-In confirmed no confirmed misuse)【38†L167-L170】. eMudhra later announced it would leave the TLS certificate business【22†L102-L105】【46†L289-L298】.

## 3. What exactly happened

eMudhra is a Bengaluru-based Certificate Authority (CA) that issues digital certificates (for websites and code signing). On **2026-10-17**, a security researcher reported that **eight of eMudhra's intermediate CA private keys** were generated with almost no randomness【38†L147-L155】【43†L28-L37】. Each P-384 key had a value under 256 – for example, one key was "4"【43†L31-L38】【38†L147-L155】. This flaw occurred during an April 2025 key-generation ceremony, when a wrap/unwrap step accidentally created a second, ultra-weak key pair【38†L147-L155】【41†L508-L516】. Because the keys were so small, anyone could compute them from the public certificates by trying only a few hundred values【43†L31-L38】【38†L147-L155】.

With any of these private keys, an attacker could **forge a TLS certificate** (for HTTPS) or a **code-signing certificate** that would be accepted as valid by software trusting that CA【38†L155-L163】. In other words, they could impersonate any site or signer under those authorities. Crucially, **no external breach occurred** – the problem was a manufacturing error, not hacking【38†L147-L155】【41†L508-L516】.

The researcher notified browser vendors immediately. Chrome's root team confirmed the report and blocked the compromised keys via a CRLSet update on Oct 17【20†L53-L61】. Firefox likewise pushed out a OneCRL update that same day【32†L23-L32】. Android and Apple platforms received similar updates by Oct 19【26†L253-L261】. eMudhra revoked all eight intermediate CA certificates on Oct 18【41†L500-L508】. By Oct 20, Microsoft had blocked them in Windows and Edge【28†L37-L44】.

eMudhra stated that **none of the eight** intermediates had ever issued certificates to customers【38†L162-L170】【41†L523-L532】. Indeed, the flaw only affected a small part of its international TLS business – its Indian digital signature (DSC) and eSign services were untouched【37†L135-L144】【41†L523-L532】. So far no fraud has been reported. CERT-In's advisory (Oct 21) noted that the public information showed **no confirmed malicious use** of the keys【38†L167-L170】.

The result is that browsers and OSs removed trust in eMudhra's affected keys and in the emSign ECC Root CA – G3 root that signed them. Most users are now protected. eMudhra offered replacement certificates to the one customer that was using the affected hierarchy【41†L523-L532】. On Oct 22, eMudhra announced it would *exit the SSL/TLS certificate business* to focus on other services【22†L102-L105】【46†L289-L298】.

## 4. Timeline

- **2025-04-30:** eMudhra generates keys for eight intermediate CAs (inside HSMs)【22†L98-L105】【41†L504-L512】.
- **2026-10-17:** Security researcher alerts root-store maintainers about weak keys; Chrome and Firefox block the vulnerable TLS-intermediate CAs within hours【20†L45-L53】【22†L99-L102】. (Chrome's CRLSet and Firefox OneCRL were updated that day【20†L53-L61】【32†L23-L32】.)
- **2026-10-18:** eMudhra revokes all eight affected intermediate CA certificates【41†L500-L508】【22†L99-L102】. (Sectigo also revokes its cross-signatures【26†L263-L268】.)
- **2026-10-19:** Apple and Google/Android block the same CAs via platform updates【26†L253-L261】.
- **2026-10-20:** Microsoft updates its Disallowed Certificate Trust List and Edge/WebView2 CRLSet to block the eight CAs【28†L37-L44】. Major Linux distributions (Debian/Ubuntu) and language runtimes release CA-bundle updates.
- **2026-10-21:** CERT-In (India's agency) publishes an advisory (CIAD-2026-0050) outlining the compromise and mitigation【37†L131-L134】【38†L147-L155】. It confirms the eight compromised keys (6 TLS, 2 code-signing) and notes eMudhra's domestic DSC business is unaffected【37†L131-L139】【38†L147-L155】.
- **2026-10-22:** eMudhra announces its board will withdraw from the global SSL/TLS certificate business【22†L102-L105】【46†L289-L298】.
- **2026-10-27:** Google schedules removal of eMudhra's emSign ECC Root CA – G3 from Chrome's Root Store【20†L53-L61】【22†L105-L108】. (Other vendors also distrust it.)
- **2026-10-30:** eMudhra issues "Update 6" noting ~30,800 certificates had been issued under the affected G3 hierarchy for a U.S. customer【26†L263-L268】. (Mozilla's tracking shows many test certs were logged, but none were in use before the block【26†L263-L268】【45†L123-L131】.)

## 5. How the attack worked

1. **Weak key generation:** In April 2025, eMudhra generated eight new intermediate CA key pairs inside Hardware Security Modules (HSMs). Due to a script flaw in the key ceremony, a *wrap/unwrap* step produced duplicate keys, and the wrong (weak) set was used for the certificates【41†L508-L516】【38†L147-L155】.
2. **Insufficient entropy:** A key needs high **entropy** (randomness) to be secure. Here each P-384 private key had only ~8 bits of entropy (value <256)【38†L147-L155】【43†L31-L38】. In practice, brute-forcing 256 possibilities takes fractions of a second.
3. **Key compromise:** Anyone with the public certificate can compute (brute-force) the tiny private key by trying 0..255 until one matches the public key【43†L31-L38】【38†L147-L155】. A private key is the secret used to create certificates.
4. **Certificate forgery:** With the private key of an intermediate CA, an attacker can sign a **TLS certificate** for any website. Browsers trust this because it chains to eMudhra's trusted root. Similarly, a compromised code-signing CA key could sign malicious software updates. This enables a *man-in-the-middle (MitM)* attack, where encrypted traffic is intercepted by a fake certificate【38†L155-L163】【43†L31-L38】.
5. **Immediate mitigation:** Once discovered, vendors **revoked** trust in the affected CAs. (Revocation is a mechanism to invalidate certificates.) Chrome used a CRLSet update blocking by *public-key hash*【20†L53-L61】; Firefox used OneCRL【32†L23-L32】; Apple and Microsoft updated their certificate trust lists【28†L37-L44】【38†L170-L178】. In effect, any certificate signed by those keys is no longer trusted. eMudhra also **revoked** the certificates at its end on Oct 18【41†L500-L508】. Finally, browsers removed eMudhra's parent root (emSign ECC G3) from their trust stores to eliminate all risk【20†L82-L90】【38†L170-L178】.

*Glossary:*

- **Certificate Authority (CA):** An entity that issues digital certificates to verify websites or software.
- **TLS certificate:** A digital certificate that secures website traffic (HTTPS).
- **Code-signing certificate:** A certificate used to sign software, making it appear from a trusted developer.
- **Private key/Public key:** A private key is a secret number used in cryptography; its matching public key can be shared openly (in a certificate).
- **Entropy (cryptographic randomness):** The measure of randomness in key generation; low entropy means easily guessable keys.
- **Revocation:** The process of marking a certificate as no longer trusted before its expiration.
- **OneCRL / CRLSet:** Browser mechanisms (Firefox's OneCRL, Chrome's CRLSet) for pushing certificate revocations quickly to all users.
- **Man-in-the-Middle (MitM) attack:** An attacker intercepts or alters communication between a user and a service, often by using a fake certificate.

## 6. Impact

No actual breach of eMudhra's systems or theft of user data was reported【34†L142-L147】【38†L167-L170】. The main impact was to the trust model: certificates issued under the affected CA hierarchy became untrusted. One enterprise ecosystem (in the U.S.) had about **30,800** certificates that had to be replaced【26†L263-L268】. Browsers and OSes had to update their trust stores (a widespread but mostly behind-

the-scenes fix). According to CERT-In on Oct 21, **no confirmed misuse** was found【38†L167-L170】. In practical terms, few or no users saw harm because browsers blocked the certificates immediately. However, any software or appliances that used their own certificate store (e.g. some VPNs or IoT devices) could have continued trusting the old keys until patched【43†L75-L84】【45†L225-L233】.

## 7. How it was fixed / what people were told to do

Vendors rolled out updates to distrust the compromised keys. For example, on Oct 17 Chrome updated its CRLSet and Firefox updated OneCRL to block the eight intermediates【20†L53-L61】【32†L23-L32】. Microsoft updated Windows Disallowed Certificate Trust Lists on Oct 20, and on Oct 26-27 released out-of-band Windows updates to remove the affected roots【28†L37-L44】【44†L55-L63】. Apple released a support note blocking the CAs by Oct 22. Server admins and developers were advised to **update their CA bundles** (Ubuntu, Debian, etc.) and rebuild any software bundling its own trust store【43†L86-L95】【32†L45-L49】. Language ecosystems did similarly: Go 1.27.3/1.26.10 and Python's certifi (2026.10.19) were released to drop eMudhra's certs【43†L79-L88】【26†L263-L268】. eMudhra provided replacement certificates (via other CAs) for impacted customers【41†L523-L532】. Users were instructed to install all security updates so that the old certificates are no longer trusted【43†L115-L122】【28†L37-L44】.

## 8. Key lessons

- **Even CAs can make basic crypto errors:** Use strong randomness (256-bit or more) when generating private keys and test key material, even inside HSMs.
- **Audits aren't foolproof:** Two external audits didn't catch this in 18 months【41†L508-L516】; organizations must monitor unusual certificate behavior independently.
- **Keep trust stores updated:** If a root or CA is compromised, only timely updates (CRL/CTL lists) protect end users.
- **Mitigate single points of failure:** Using multiple, independent CAs (CA redundancy) can limit impact if one CA's keys fail【41†L562-L571】.
- **Monitor certificate transparency:** CT logs and scanners help detect unexpected certificates; no fraudulent cert was in CT logs before the fix【20†L63-L69】【45†L165-L173】.

## 9. Glossary

- **Intermediate CA:** A CA that is itself certified by a root CA to issue end-entity certificates.
- **TLS certificate:** See above (secures HTTPS).
- **Code-signing certificate:** See above.
- **Private/Public Key Pair:** The secret (`private key`) and corresponding `public key` used in public-key cryptography.
- **Entropy (cryptography):** Randomness used in generating cryptographic keys. More entropy = more security.
- **Certificate Revocation:** Marking a certificate (or key) as invalid before its expiry.
- **Trust Store:** A list of root CA certificates that a browser or system trusts by default.
- **OneCRL/CRLSet:** Mechanisms used by Firefox/Chrome to quickly distribute certificate revocations to users.

## 10. Sources


[S1] **CERT-In Advisory CIAD-2026-0050: Compromise of eMudhra Intermediate CA Certificates**. *Indian Computer Emergency Response Team (CERT-In)*. 2026-10-21. Official advisory detailing the incident and mitigation; confirms eight compromised keys (6 TLS, 2 code-signing) and timeline of blocks【37†L131-L134】【38†L147-L155】. *Type:* Government/Primary.

[S2] **Protecting Chrome and Android Users from Compromised eMudhra Intermediate CA Certificates**. *Google Chrome Security Blog*. 2026-10-20. Describes Chrome's action: Oct 17 report, CRLSet block of the eight intermediates, and planned root removal【20†L45-L53】【20†L53-L61】. *Type:* Official/Primary.

[S3] **Protecting Firefox users following the compromise of eMudhra intermediate certificates**. *Mozilla Security Blog*. 2026-10-20. Details Mozilla's response: Oct 17 report at 20:06 UTC, OneCRL block by 22:59, and root removal in NSS【32†L23-L31】【32†L39-L46】. *Type:* Official/Primary.

[S4] **Microsoft's response to compromised eMudhra certificate authority keys**. *Microsoft Security Response Center (MSRC)*. 2026-10-26 (updated 10/27). Explains Microsoft's measures: blocking the 8 CAs on Oct 20, updating trust lists, and removing roots on Oct 26-27【28†L37-L45】【28†L53-L62】. *Type:* Official/Primary.

[S5] **eMudhra Statement on Recent Certificate Security Incident**. *eMudhra*. Updated Oct 2026. eMudhra's public incident blog post confirming revoked intermediates (Oct 18) and that no end-entity certs were issued under them【41†L500-L508】【41†L523-L532】. *Type:* Official/Primary.

[S6] **eMudhra Intermediate CA Certificate Key Compromise — 443 Labs Security Advisory**. *443 Labs*. 2026-10-23. Independent advisory summarizing the incident. Provides root cause (weak P-384 keys), lists affected CAs (6 TLS, 2 code-signing), and a concise timeline【22†L78-L86】【22†L98-L105】. *Type:* Researcher.

[S7] **eMudhra CA Key Compromise (Oct 2026)**. *Illumen (security blog)*. 2026-10-23. Detailed analysis and timeline: shows steps of the key ceremony, timeline of blocks and fixes, and impact numbers (e.g. ~30,800 certs)【26†L263-L268】【26†L346-L354】. *Type:* Researcher.

[S8] **Mozilla, Google, Apple block compromised eMudhra CA certificates**. *BleepingComputer* (Lawrence Abrams). 2026-10-20. News report summarizing discovery (Oct 17) and responses; notes "private key… value of just 4" example【43†L31-L39】【43†L59-L66】. Includes a table of software fixes. *Type:* News.

[S9] **CERT-In issues advisory; MeitY probes eMudhra incident**. *Press report (IANS via MenaFN)*. 2026-10-21. Covers CERT-In advisory and MeitY probe. Confirms 8 affected CAs (6 TLS, 2 code-signing) and that India's DSC/eSign services were unaffected【34†L128-L136】【34†L142-L147】. *Type:* News.

[S10] **eMudhra CA compromise: What it means for you**. *Nexussec (blog)*. 2026-11-01. Summary article (for security readers) recapping the event. Useful for consolidated facts: dates of blocks (Chrome/Firefox Oct 17, Apple Oct 19, Microsoft Oct 20) and CERT-In's finding of no confirmed misuse【35†L43-L52】【35†L55-L64】. *Type:* Researcher.

[S11] **eMudhra CA Key Compromise: How to Respond When Your CA Loses Trust Overnight**. *Keyfactor (blog)*. 2026-10-29. Industry analysis. Confirms timeline of discovery and revocation, block timings, and notes eMudhra's Oct 22 exit【46†L229-L238】【46†L289-L298】. Lists vendor actions and CVEs (Go, Python, Java, NetApp, etc.). *Type:* Researcher.

## 11. Verification notes

- The CERT-In advisory (CIAD-2026-0050) was obtained from CERT-In's website and fully confirms the key details.
- eMudhra's own statements and browser security blogs match each other on dates/events.
- We found no conflicting data among primary sources. (One discrepancy: Illumen noted eMudhra's Oct 28 update saying ~30,800 certs were affected【26†L263-L268】, whereas eMudhra earlier said none had issued any certs【41†L523-L532】. We report both: Illumen vs eMudhra.)
- The CVEs (2026-108015, 2026-22063) were confirmed via Rapid7/ScoRISK sites【6†L406-L414】【9†L43-L46】 and OffSec blog【45†L147-L155】.
- All key dates fell within 17–22 Oct 2026. Nothing essential from outside that range (the Chrome root removal on Oct 27 is beyond but mentioned as follow-up).
- All claims above are cited to open sources. No claim is made without a source.

---